

3MTT CAPSTONE ASSESSMENT REPORT

Enterprise MFA Rollout & Authentication Governance Framework

Candidate	Ahmad Mukhtar
Programme	3MTT Nigeria (Airtel x NITDA)
Track	Cybersecurity
Institution	Kano State Polytechnic
Project Title	SME MFA Rollout
Policy Focus Area	Identity & Access Management (IAM)

Prepared for 3MTT Cybersecurity Capstone Submission

Final report prepared from the supplied project report. Technical validation statements reflect the project evidence described in that source document.

1. Executive Summary & Context

Credential harvesting and password abuse remain significant risks for small and medium-sized enterprises (SMEs). Password-only authentication can expose organisational systems to brute-force attacks, phishing and credential stuffing. This capstone presents an enterprise-oriented Multi-Factor Authentication (MFA) rollout strategy combined with a mandatory password governance policy.

The framework is designed for resource-conscious SMEs and focuses on strengthening identity and access management (IAM) through stronger password requirements, mandatory MFA, phased deployment and practical technical verification.

Project Aim

To establish a practical MFA governance and rollout framework that reduces account-takeover exposure while providing a controlled, phased path to organisation-wide adoption.

2. Corporate Security Policy Specification

POL-IAM-001: Passphrase & Password Governance

Control	Requirement
Minimum password length	14 characters for standard staff; 16 characters for administrative roles.
Complexity	Uppercase, lowercase, numbers and special symbols; 3–4 random-word passphrases are encouraged.
Account lockout	Automatic account suspension for 30 minutes after 5 consecutive failed login attempts.
Prohibited passwords	Dictionary words, company names, seasonal years and passwords identified in breach databases.

POL-IAM-002: Mandatory MFA Governance

Control	Requirement
Enforcement scope	Mandatory for internal staff, contractors and third-party vendors accessing organisational resources.
Approved second factors	TOTP applications such as Google Authenticator or Microsoft Authenticator, or hardware tokens.
Disallowed factor	SMS-based OTPs are to be phased out because of SIM-swapping and interception risks.
Grace period	Maximum 7-day onboarding window for new hires before enforcement blocks access.

3. Phased MFA Implementation Strategy

Phase	Timeline	Target group	Key execution tasks	Risk mitigation
1	Week 1	IT & Global Admins	Configure Identity Provider (IdP) policies, baseline testing and a broken MFA enforcement	Establish a safe testbed
2	Week 2	Pilot Group (15%)	Deploy to tech-savvy users across Finance, HR and Operations, gather feedback	Identify issues, provide training before company-wide
3	Week 3–4	Company-wide	Full enforcement and automated lockout for non-compliance	Support and controlled adoption, grace period, dedicated

4. Technical Lab Architecture & Verification

The supplied project report describes a simulated enterprise environment established using VirtualBox, with a Linux/Windows server environment and an Identity Provider (Keycloak / Google Workspace Sandbox).

Lab Validation Test Case

The documented validation test uses a two-stage authentication flow. An authentication attempt using the correct primary credentials without the required TOTP token resulted in an HTTP 401 Unauthorized response / MFA challenge prompt. After the QR code was enrolled with Google Authenticator and a six-digit TOTP was supplied, access was successfully granted with token rotation.

Test step	Expected / documented result
Primary credentials without TOTP	HTTP 401 Unauthorized / MFA challenge prompt.
TOTP enrolment	QR code scanned using Google Authenticator.
Primary credentials + valid TOTP	Access granted; token rotation documented.

5. Security Benefits & Governance Rationale

The proposed control model addresses the risk of relying on passwords as the sole authentication factor. Mandatory MFA adds an additional authentication layer, while password governance reduces exposure to weak, reused or compromised credentials.

The framework also separates implementation from enforcement by introducing administrator testing, a 15% pilot group and staged company-wide rollout. This reduces operational risk and provides an opportunity to identify onboarding or user-experience issues before full enforcement.

Important evidence boundary

The supplied report documents the technical validation described above. Any screenshots, logs or live demonstration presented during assessment should correspond to the actual lab session and should not expose real passwords, recovery codes, private keys or other secrets.

6. Recommended Security Controls

Priority	Recommendation
High	Enforce MFA for privileged and organisational accounts accessing protected resources.
High	Use TOTP applications or hardware tokens rather than relying on SMS-based OTP as the preferred second factor.
High	Apply strong password/passphrase requirements and prohibit known compromised passwords.
Medium	Use a staged rollout with administrator testing and a pilot group before company-wide enforcement.
Medium	Provide onboarding assistance and a defined recovery process to reduce account-lockout disruption.

7. Conclusion

This capstone presents a practical SME-focused approach to strengthening identity and access management through mandatory MFA and password governance. The documented laboratory validation demonstrates the intended authentication behaviour: primary credentials alone do not complete access when MFA is enforced, while a valid TOTP enables successful authentication.

The phased deployment strategy provides a controlled route from administrator testing to pilot deployment and finally company-wide enforcement. The project therefore combines policy governance with a practical technical verification model suitable for an SME environment.

Prepared by Ahmad Mukhtar | 3MTT Nigeria (Airtel x NITDA) | Cybersecurity | Kano State Polytechnic